ARCHITECTURE & CAPABILITY BOOK

Agent OS（oaagent-m0）架构与功能全书

让一句话变成一次可验收的交付

流程闸 · 判据闸 · 成本闸 · 权限闸 —— 四道由数据库强制执行的硬约束

v5.1 现状快照 · 2026-10-25

代码基线 mainline @ 924346b

事实来源：仓库源码 + 运行库快照 + 真机启动验证

用途：交接 / 评审 / 交由推理模型规划后续方向

0 • 阅读指南与事实基准

本文是 Agent OS 的**完整架构与功能说明书**，写给两类读者：一是新接手工程的人，二是需要据此规划后续演进方向的外部推理模型。文中每一条架构断言都对应仓库里的真实文件；每一个数据都来自 2026-10-25 的实际运行快照，不是设计意图的复述。

项	值
代码基线	分支 mainline，提交 924346b（v5.0），另有 24 改 + 33 新增未提交（即 v5.1 工作区）
后端规模	98 个 Python 模块，22,023 行
前端规模	16 个源文件，7,823 行（React 18 + Vite 5，手写 CSS）
测试规模	57 个测试文件，405 个用例
接口规模	167 个 HTTP 路径，分 16 个标签组
数据规模	71 张表 + 5 个触发器，主库 30 MB
桌面壳	Tauri 2，产物 AgentOS-<ver>.exe + NSIS 安装包（当前 dist 只有 3.2.0 与 4.3.0）

> 读法建议：想快速判断「这系统能干什么」读 §1–§5；想评估工程质量读 §20–§22；想让模型规划方向，把 §23–§25 整段喂进去即可，其余作为依据。

1 • 一句话定位

这是一个让老板用一句话驱动一整家公司干活的系统。需求进去，系统自己立项、拉团队、拆活、执行、验收、出货、复盘；过程中不允许跳步、不允许蒙混、不允许超支——三条都由数据库层强制，而不是靠提示词祈祷。

它要解决的问题

- AI 只会聊天，不会承担交付责任：没有立项、没有验收判据、没有证据链。
- 多 Agent 协作退化成角色扮演：谁都能说自己做完了，没有第三方判定。
- 成本不可控：一次跑飞能烧掉几万 token，账要月底才知道。
- 过程不可见：老板只能看到结果，看不到卡在哪、谁在拖、钱花在哪。

它给出的答案（四道硬闸）

闸	机制	物理位置	敌人
流程闸	阶段不可跳；闸门不过不许 done；一票否决即停摆	SQLite 触发器 ×4	AI 自我感觉良好
验收闸	L0 红线 → L1 人工（必须带证据）→ L2 沙箱真跑脚本	app/acceptance_run.py	空话交付
成本闸	阶段额度 → 80% 暂停 → 划拨审批 → 断点续跑	app/finance.py + runner	预算失控
权限闸	资源级 RBAC；高危工具转审批单；会话可 park/resume	app/rbac.py	越权操作

目标用户：一个非技术的决策者（文中称「董事长/CEO」） + 一个技术负责人。前者发号施令并看板，后者维护角色、判据与预算。

2 • 系统全景：五层架构

控制面 • 前端	‣ React 控制台（14 个视图） ‣ 赛博指挥舱（默认首屏，9 站点实时点亮） ‣ Tauri 桌面壳 / NSIS 安装包 ‣ SSE + WebSocket 遥测
接入面 • BFF	‣ app/ui/api.py（79 端点） ‣ admin / ops / extensions / governance / housekeeping ‣ Bearer + Cookie 双鉴权，租户与实体双重校验
业务面 • 领域	‣ 调度：dispatcher / roles / router_llm / intent ‣ 产线：pipeline / flows / task_generator / pipeline_llm ‣ 判据：acceptance_run / l0 / l1 / l2 / redline ‣ 财务：finance / finops ‣ 治理：experience / evals / governance ‣ 组织：tenancy / tenant / rbac / role_alignment
执行面 • 内核	‣ kernel_router（双引擎热切换） ‣ runner_native（进程内 Agent 循环，765 行） ‣ runner_acp + acp_client + dsh_adapter（外部 CLI 子进程） ‣ sandbox_env / lowil（Windows 低完整性标记） ‣ locks / idempotency / trace
数据面 • 存储	‣ SQLite 单文件 71 表（WAL） ‣ 5 个触发器守流程与状态 ‣ 文件产物：workspace/projects/<P-id>/ ‣ 审计：ai_audit_logs（11,460 行）

贯穿各层的东西

- 遥测总线 `app/telemetry.py`：任何一层发生状态变化都 emit 事件，前端订阅即点亮。
- 审计 `app/audit.py`：唯一的审计写入点，任何关键动作都留一行。
- 状态机 `app/state_machine.py`：任务状态只能按表迁移，DB 触发器做第二道防线。
- 错误翻译 `app/errors.py` + 前端 `humanize()`：机器码留后端，人话给用户。

3 • 运行时拓扑

组件	进程 / 位置	端口	说明
底座 API	uvicorn app.main:app	8077（生产）/ 8078（验证副本）	单 worker 硬约束，SQLite 不支持多写
控制台	同进程静态挂载 /app	—	web/dist 由 Vite 构建，base="./" 同时服务浏览器与 Tauri
桌面端	oaagent-console.exe（Tauri/WebView2）	—	走 Bearer，不用 Cookie（tauri:// 与 127.0.0.1 跨站）
执行内核	HTTP 时进程内 Native；或 dsh CLI 子进程	—	由 kernel_router 决定，见 §8
遥测通道	WebSocket /ws/metacorp	—	广播 RUN_TRACE_EVENT / PIPELINE_STAGE_CHANGED / ACP_USAGE_UPDATE 等
数据库	data/oa.db（SQLite，WAL）	—	72 张表（含 sqlite_ 内部表），主库 30 MB
产物	%LOCALAPPDATA%\oaagent-m0\workspace（23 MB）	—	另有一份在仓库 workspace/（见 §24 缺陷 4）
企微	qyapi.weixin.qq.com	443	群机器人 webhook + 应用消息 + 原生审批
模型	DeepSeek 兼容 HTTP API	—	MODEL_BASE_URL 可替换；单价见 MODEL_PRICES_JSON

> 启动：scripts/start_all.ps1（含审批轮询、DSH 桌面端互斥检测），或 ~/bin/agentos-server.cmd 做健康检查幂等的拉起。

4 • 核心因果链：一条需求的全生命周期

① 输入	CEO 在调度台/群聊丢一句话，或桌面端「立即启动流水线」
② 意图闸	is_chitchat 判闲聊（短句含你好/谢谢等直接对话，不建项目）；否则进路由
③ 路由	roles.tags_of 关键词命中 → 未命中才调便宜模型兜底，返回 dev/content/qa 等标签
④ 规划	flows.plan 产出流程模板与阶段 DAG（软件/分析/调研/紧急四类 + 复合流）
⑤ 立项	pipeline.create_project 一次性落 9 个阶段，绑定实体、租户、预算池
⑥ 拉人	roles.pick 只拉规划里用到的角色；role_templates 缺人就地实例化 AI 员工
⑦ 执行	逐阶段：研讨(4 轮) → 黑板 → WBS → 建 Task → kernel 跑 → 产物落盘
⑧ 判定	acceptance_run：L0 红线 → L2 脚本 → L1 人工（带证据）→ 状态机推进
⑨ 出货	release 阶段打包 zip → 企微群机器人闭环通知 → retro 沉淀经验晶石

每一步的落地代码：`app/ui/dispatcher.py:138` → `app/flows.py` → `app/pipeline.py:229` → `app/ui/roles.py` → `app/pipeline.py:execute_build` → `app/acceptance_run.py:270` → `app/pipeline.py:run_stage` → `app/experience.py`。

> 关键设计取舍：路由与规划都**先确定性后模型**。顺序反了的话，每条闲聊都会烧一次 token——这是踩过的坑，不是洁癖。

5 • 九阶段流水线明细

#	阶段 key	名称	主责角色	闸门名	通过条件	产物
1	intake	接需求	product	需求可交付	需求要素齐全、可追溯	需求记录
2	charter	立项	product	立项书章节完整	目标/范围/预算/里程碑齐全	立项书
3	workshop	研讨	architect	全员留下风险意见	4 轮：提案-质询-修订-表决	研讨纪要
4	wbs	拆解	architect	DAG 无环且依赖可满足	任务可执行、依赖闭合	WBS + 黑板
5	build	实现	dev	代码可运行	全部 WBS 任务 succeeded	源码 / 文档 / 页面
6	test	测试	qa	测试报告通过	语法检查 + 限时真跑	测试日志
7	accept	验收	product	验收通过	L0/L1/L2 全绿且证据齐全	验收单
8	release	发布	ops	发布清单全部勾选	清单齐全、包可下载	release zip
9	retro	复盘	product	含改进项	至少一条可复用经验	经验晶石

阶段定义在 `app/pipeline.py:22`；闸门与阶段状态由 4 个触发器守着：

- `trg_stage_no_skip`：前序阶段未 done，后序阶段不允许 active。
- `trg_stage_gate_guard`：阶段存在未通过的必需闸门时，不允许标 done。
- `trg_gate_veto_ins/upd`：闸门被标为否决（veto）时，项目直接进入 blocked，不允许强行推进。
- `trg_tasks_state_guard`：任务状态只能按状态机表迁移，裸 UPDATE 会被拒。

> 这三条是「产品承诺」的物理实现。绕过它的唯一方式是关掉 SQLite 触发器——而这在代码里没有任何开关。

6 • 流程模板与规划层

模板 ID	名称	阶段数	用途
FLOW-SOFTWARE	标准 9 阶段软件工程流水线	9	默认；代码/页面/工具类需求
FLOW-STANDARD	标准 9 阶段软件工程流水线	9	与上者完全重复（技术债，见 §24-10）
FLOW-ANALYSIS	业务数据分析流	4	取数、归因、结论
FLOW-RESEARCH	行业竞品调研流	4	检索、对标、研报
FLOW-URGENT	紧急排障抢修流	4	止血优先，记录后补

复合流与 DAG

- 模型判定需求含两个目标时，`_compose_nodes` 把两套模板拼成一个 DAG，副流程 key 加前缀避免冲突，交付节点统一收到最后。
- WBS 支持上游黑板上下文（`project_artifacts`）：下游任务不必重读文件，直接吃上游结论。
- 阶段级预算 `M0_FLOW_STAGE_BUDGET` 默认 30k，可被项目池覆盖。

意图闸的三档

档	触发	动作
闲聊	短句 + 你好/谢谢/在吗	直接自然语言回复，不建项目
低置信 work	分类置信度 < 0.6	会话内追问「要报告还是小工具」，返回 clarify=True
明确 work	命中标签或高置信	建项目 + 拉群 + 起首轮

> 线上故障/宕机/止血这类词会硬覆盖进紧急流——不能等模型慢慢分类。

7 • 双内核执行层（当前最需要澄清的一块）

执行层被抽象成可插拔内核，由 `app/engine/kernel_router.py` 统一调度：

模式	含义	实际行为
native	进程内内核	NativeKernel 直接调模型 API，自带工具集，零子进程
dsh	外部 CLI 内核	起 dsh --profile acp 子进程，走 JSON-RPC，事件流回传
auto_failover（默认）	Dsh 优先、失败降级	仅当 M0_PREFER_DSH=1 才先试 DSH；否则直接 Native

NativeKernel 是什么

`app/engine/runner_native.py`（765 行）是一个完整的进程内 Agent 循环：模型调用 → 工具调用 → 产物落盘 → 用量记账，工具为受控白名单（write_file / read_file / run_script 等），每一步都 emit 遥测并写 Trace span。

DSH ACP 通道

`runner_acp.py` + `acp_client.py`（818 + 207 行）通过 stdio JSON-RPC 驱动外部 CLI：session/new、prompt、tool_call 通知、usage_update、cancel。工具调用时做 RBAC 判定，命中高危就 park 成审批单（§12）。

> ⚠ 现状漂移：`.env` 里是 UI_RUNNER=acp，但 dsh_adapter.py:633 把 acp/mock_acp/native/auto 四种 runner 全部交给 kernel_router，而 kernel_router 默认 auto_failover 且 M0_PREFER_DSH 未设置 → **实际跑的是 NativeKernel，DSH 子进程根本不会起。**这不是配置问题，是语义与命名脱节：写 acp 的人以为在跑 ACP。7 个守卫生效的测试因此变红（断言 -9 退出码、断言 runner=='mock_acp'）。

8 • 工具、沙箱与额度

机制	实现	要点
工具白名单	runner_native 内建 + mcp 外部工具	只暴露确定性、可审计的工具
工具调用上限	runner_acp._tool_cap_check	搜索 >5 次 / 抓取 >3 次直接 cancel，记 tool_cap_exceeded
工具 ACL	app/tools_acl.py	按角色绑定工具，执行期真拦，不只是提示词
Windows 沙箱	app/engine/lowil.py + sandbox_env	任务目录打 Low 完整性标签；工作区根保持 Medium（防逃逸）
静默提权	Win32 SetNamedSecurityInfoW	不调 icacls、不弹 UAC；实测 0.07s
网络	不限制	业务单要抓数据，断网交给 Prompt 约束（产品决策）

> 沙箱只防写系统目录，不防联网——这是刻意取舍。测试 test_m0_20 是逃逸探针：给工作区根打 Low 会让它立刻变红。

9 • 验收与合规：三层判据 + 证据链

层	名称	谁判	通过条件	失败后果
L0	红线/合规	规则引擎	不含禁用词、不含极限广告词	直接 rejected，无人工入口
L2	确定性断言	脚本（沙箱子进程）	验收脚本 exit 0 且断言通过	rejected，重跑带失败清单
L1	人工裁决	人（CEO/负责人）	必须附 evidence_snippet 证据片段	缺证据抛 EvidenceRequired

为什么需要证据链

三条判据都写进 `acceptance_criteria`（4,406 行）、证据指向 `evidence_refs`（1,289 行）、红线扫描留 `redline_scans`（456 行）。所以「通过了」永远可以回溯到「哪一条、谁判的、依据是什么」。

判定流

1. runner 结束 → 收集产物 → 逐条算判据（L0 先、L2 次、L1 最后）
2. 任一 L0 命中 → 整单 rejected，不进入人工
3. L2 失败 → 把失败断言清单拼进下一轮 prompt（不是重新开始，是带伤重跑）
4. 全绿 → state_machine.transition('review_passed') → 阶段闸门放行

> 字数类判据自 v1.5 起是非阻断的：写了 400-600 字就照办，没写就默认 600-1500，不达标只提示交人工。
> 自动扩写自愈已关闭——它把 900 字好稿改成 1300 字注水稿，还反复烧 token。

10 • 预算与成本：三级预算 + 80% 暂停

层级	对象	算法	熔断
阶段额度	project_stages	base_estimate(kind/role) × 复杂度(0.9/1.0/1.15) × 紧急(1.2) × 弹性(1.5)	到 80% 暂停并申请划拨
项目池	projects	Σ 阶段额度；超 project_budget_cap 等比压缩（地板 3000/阶段）	压缩后仍超则逐个减 500
运行预算	task_runs	est_tokens 预留 → 实际用量回填 usage_baseline 差值	预算不足 exit 5 / budget_exhausted

暂停与恢复的真实语义

- run 在 usage_update 里实时比对 baseline+pause_at，到线即 cancel，标记 `budget_pause`。
- 阶段捕获 BudgetPause 时**不能**标 blocked（预算暂停不是失败），这是踩过的坑。
- 划拨只动 stage_budgets.quota，不动池子总量；批准后 POST /ui/projects/{id}/resume 从断点**重跑未完成阶段**。
- 重跑会重新花 token——它不是会话续跑，这点必须跟老板讲清楚。

FinOps 折算

`app/finops.py` 把 usage_tokens 按模型单价折人民币（MODEL_PRICES_JSON，输入占比 FINOPS_INPUT_RATIO=0.75）。ACP 只回总量，所以**必须标注为估算**；无归属实体的开销显示「未归属」，不硬塞部门。

11 • 权限、审批与断点续跑

概念	表 / 模块	说明
资源	resources	RES-DEV / RES-FIN 等资源目录，带真实越权演练
授权	agent_permissions	角色 × 资源 × read/write/admin
高危工具	db_exec / file_delete / shell_exec	默认拦截，生成审批单而非直接失败
审批单	tool_approvals	存 run_id + session_id + tool + rawInput + target（续跑必需）
续跑	approval_flow + rbac.park_run	状态改 awaiting_approval，任务保持 in_progress

为什么是「平台代执行 + session/resume」

1. ACP tool_call 通知到达时判 RBAC，未授权就 cancel 并发通知，**不发 run_failed**（发了任务就变 failed，只能重试不能续跑）
2. 审批单落库，企微推送卡片，站内也有审批中心
3. 批准后由平台按 rawInput **逐字节代写**，校验 realpath 在资源内、审计 sha256
4. 同一 session 续跑，prompt 只让 Agent「读回确认后继续」
5. 一次性审批在代执行成功后消费；同一目标的重试写复用 approval_reused，避免批准死循环

> 为什么不直接给 Agent 放开目录写权限：DSH 的 workspace-write 会把 shared/ junction 按 realpath 判成出域，批准了照样写不进去，Agent 还会尝试危险模式。平台代执行是唯一稳的路径。

12 • 多租户与组织模型

层	模型	隔离点
租户 tenant	tenants（TENANT-HQ / TENANT-BETA…）	identities / projects / chats / mcp_servers / tasks / runs / artifacts / approvals 带 tenant_id
法人实体 entity	legal_entities（LE-GROUP-HQ…）	可见域过滤；签名接口的 entity 作用域
身份 identity	identities（22 条）	HMAC 签名 + nonce 防重放
组织树	通用递归组织树	任意层级部门，非固定两层

登录返回 tenant_id，前端 api.js 自动加 X-Tenant-Id；后端 `_tenant_of()` 用身份自己的租户校验，**外来 header 直接 403 TenantMismatch**（不是 404，避免掩盖配置错误）。

> 残留：组织经验与评测集是组织级共享，未按租户切分。SaaS 化之前必须收口，否则知道 ID 就能跨租户读经验。

13 • 记忆、经验与知识

资产	表	来源	注入点
组织经验	org_experiences（465 条）	任务驳回 / 研讨会共识 / 决策否决 / 手工	立项时按标签+词面召回 3 条
红线	org_experiences(mandatory=1)	董事长手工签署	每个 Run 的 prompt 尾部无条件追加
黑板	project_artifacts（151 条）	各阶段写结论	下游阶段读黑板，不重读文件
评测集	eval_sets / eval_runs	Run 详情「设为基准用例」	prompt_mode=stored 复现基准
知识库	settings + docs.py	上传文档解析（PDF/文本）	最近 3 个各 6k 字进 prompt

经验审核闸（唯一入口）

`org_experiences.state` 是唯一注入闸门：`context_for()` 只查 approved。新经验显式写 pending，人工审批后写审计 experience_reviewed。直接 UPDATE state 会让界面与审计打架。

> 数据信号：当前 465 条经验里只有 12 条 approved、452 条 pending、1 条 rejected。审核队列已经积压成灾——这不是技术 bug，是产品流程设计问题（见 §25）。

14 • 交付、通知与外部协同

能力	模块	说明
出货打包	pipeline.run_stage(release)	html/md/py/json 收进 release/ 并压成 <P-id>_release.zip
企微群机器人	app/wecom/robot.py	按租户配 webhook；先记账再后台投递，推送不是闸门
企微应用消息	wecom/client.py	access_token 缓存 + 文本/模板卡片；未配凭据自动降级到 Web 舱
企微原生审批	wecom/approval.py	让董事长在手机上签 L1 人工判据
签名页	wecom/sign_page.py	一次性签名链接，手机点开即签
邮件 MCP	tools/mcp_email_server.py	支持附件；配了 SMTP 却失败必须报错，不能退回 outbox 冒充已发
MCP 交易所	app/mcp_bridge/	部门包 blueprint 导出/导入 + 跨公司雇人执行子任务

投递语义很关键：**先记账再投递**（notifications 表唯一键 tenant+event+ref），投递失败只标 failed，不回滚业务。所以「通知没发出去」永远不会变成「项目失败」。

万界 MCP 交易所（v5.1 新）

- 服务端 `mcp_server.py`：标准 JSON-RPC 2.0，暴露 run_l2_audit / inspect_pack / execute_stage 三个工具。
- 打包 `pack_exporter.py`：把一个部门（角色 + prompt + 经验 + 预算）导出成 .metacorp.json，带 checksum。
- 雇人 `mcp_client.py`：外部 endpoint 执行子任务，产物合并回本项目。
- 定位：将来可以「卖部门」——别的公司导入你的内容营销包就能开张。

15 • 前端控制台

视图	组件	行数	作用
赛博指挥舱	CyberFactorioDeck.jsx	1,105	默认首屏：9 站点实时点亮、KPI、CEO 指令台、内核切换、MCP 交易所
工作台/任务	Workspace.jsx	120	我的任务、待办、快捷新建
总装流水线	MissionControl.jsx	957	项目看板、发布包导出、预览
项目流	ProjectFlow.jsx	350	阶段流、失败诊断、重试
治理/恢复	GovernanceView.jsx	136	经验审核、项目解冻
工具与集成	ExtensionsView.jsx	242	MCP、SMTP 设置
系统维护	MaintenanceView.jsx	145	残留清理、批量删
其余 7 个	App.jsx 内联	3,569	任务/会话/产物/审批/组织/角色/用量/评测/经验

交互与鉴权的不变量

- Vite `base: "./"`：一份 dist 同时服务 FastAPI 的 /app/ 和 Tauri 的 tauri://localhost；改成 /app/ 会让 exe 白屏。
- 桌面端走 Bearer：tauri:// 与 127.0.0.1 跨站，Cookie 不成立；后端 _token 同时接受两者。
- 模型输出不可信：marked 关掉 raw HTML + safeHtml 二次清洗，才敢 dangerouslySetInnerHTML。
- SSE 走 /ui/chats/{id}/stream，nginx 必须 proxy_buffering off。

> 前端最大的结构债：App.jsx 单文件 3,569 行，14 个视图里 7 个内联在里面。改一个视图要读半个文件。

16 • 遥测与可观测性

信号	落点	用途
RUN_TRACE_EVENT	run_stream（1,203 行）+ WS	实时看思考/工具调用/结果
PIPELINE_STAGE_CHANGED	WS + 指挥舱站点	九阶段实时点亮
ACP_USAGE_UPDATE	budgets / finops	逐次调用 token 与人民币
EXP_CRYSTAL_DROP	WS + 晶石库	经验沉淀的可视反馈
trace_spans / agent_traces	1,092 / 459 行	一次 Run 的分段耗时瀑布图
ai_audit_logs	11,460 行	谁在什么时候对什么做了什么

Trace 有两个坑已修：agent_thought_chunk 通常整块到达，thinking span 起点要取上一事件结束；token 归因用「本 run 已累计 usage」而非 session_baseline。

17 • 数据模型（71 表，按域分组）

域	表	行数示例
身份与租户	tenants / legal_entities / identities / auth_nonces	22 身份 / 327 nonce
组织与角色	ai_employees / role_templates / roles / agent_permissions / resources	角色库 + 权限矩阵
项目与阶段	projects / project_stages / stage_gates / stage_budgets / stage_deliverables	7 项目 / 59 阶段 / 162 闸门 / 148 交付物
任务与执行	tasks / task_runs / run_stream / locks / budgets	597 任务 / 621 Run / 548 预算行
判据与证据	acceptance_criteria / evidence_refs / redline_scans	4,406 / 1,289 / 456
产物与文件	artifacts / project_artifacts / preview_tickets	1,866 / 151
协作与会话	chats / chat_messages / chat_members / group_hops	34 会话 / 269 消息
记忆与评测	org_experiences / eval_sets / eval_runs / eval_results	465 经验
审批与合规	tool_approvals / approvals / alerts	审批单 + 告警
集成与通知	mcp_servers / wecom_robots / wecom_robot_outbox / notifications / settings	442 通知
审计与追踪	ai_audit_logs / agent_traces / trace_spans / idempotency_keys	11,460 / 459 / 1,092
流程模板	flow_templates / wbs_items / packs	5 模板 / 24 WBS / 7 包

触发器（4 条硬约束 + 1 条状态机）

- trg_gate_veto_ins
- trg_gate_veto_upd
- trg_stage_gate_guard
- trg_stage_no_skip
- trg_tasks_state_guard

> 数据现实：tasks 597 条里 rejected 459 条（77%）、completed 30 条；task_runs 621 条里 succeeded 519、failed 87。说明「跑得通」已经实现，但「跑得对」还差得远——这是判断产品阶段最重要的两个数字。

18 • 接口面（167 个路径）

标签组	端点数	覆盖面
ui	79	见附录 B
ui-admin	26	见附录 B
extensions	14	见附录 B
wecom	14	见附录 B
tasks	11	见附录 B
octo	8	见附录 B
ui-ops	7	见附录 B
governance	7	见附录 B
decisions	6	见附录 B
mcp-exchange	6	见附录 B
verbs	6	见附录 B
(none)	4	见附录 B
memory	3	见附录 B
reports	2	见附录 B
housekeeping	2	见附录 B
relay	1	见附录 B

统一约定：/ui/* 走 BFF（Cookie 或 Bearer），/api/* 走 HMAC 签名（六动词 + 任务），/mcp-exchange/* 是标准 JSON-RPC，/ws/metacorp 是唯一 WebSocket。

> BFF 是最大的单文件：app/ui/api.py 2,855 行、79 个端点。它已经接近「什么都往里塞」的临界点。

19 • 安全模型

层	机制	备注
请求签名	HMAC-SHA256 + nonce 表（防重放 327 行）	/api/* 强制
控制台鉴权	Cookie（浏览器）/ Bearer（桌面）	登录返回 token + tenant_id
企微回调	签名校验 + AES-256-CBC + MsgId 幂等 + IP 白名单	app/wecom/crypto.py + guard.py
沙箱	Windows Low 完整性标签，只打任务目录	不限制联网（产品决策）
模型输出	marked 禁 raw HTML + 二次清洗	防 XSS
密钥	.env（git 忽略）/ settings 表（SMTP 密码只回 pass_set）	对外发布必须脱敏快照

> 已知风险：仓库根 e2e_supervisor.py 硬编码了 CEO 身份 ID + 64 位 secret（未跟踪，但 git add -A 就进库）；docs/_wecom_cb.txt 与截图里有真实企微 Token 与 AESKey，已 gitignore 但仍在磁盘上。

20 • 工程质量现状（真机验证，2026-10-25）

项	结果	说明
服务启动	✅ 通过	生产库副本起 8078，/health ok、/app/ 200、MCP 工具列表正常
默认首屏渲染	✅ 通过	赛博指挥舱整页渲染，pageerror = 0，仅 favicon 404
全量测试	⚠ 498 passed / 55 failed / 11 errors	红灯集中在 3 个根因（见 §24）
从仓库根跑 pytest	❌ 收集阶段中断	workspace/projects/*/test_check.py 被当测试收集
桌面安装包	⚠ 落后两个大版本	dist 只有 3.2.0 与 4.3.0，而代码已 v5.1
公开仓同步	⚠ 落后 20 个提交	origin/main 停在 v4.x

测试分布

57 个文件、405 个用例。覆盖面最广的是治理（21）、地基 m0（20）、扩展（19）、租户（15）、意图（15）。最大的一块是 v4/v5 系列增量测试，说明这套系统是「边加功能边补断言」长出来的，不是先设计后实现。

21 • 版本演进史

版本	主题	关键能力
v1.0	地基	六动词、状态机、L0/L1/L2 判据、审计、HMAC、租户隔离
v1.1–v1.3	可用性	拟人化、三栏 UI、圆环图标、安全护栏、免 UAC 沙箱
v1.4	调度	CEO 调度台、角色库、标签路由 + 模型兜底
v1.5–v1.6	产线	项目/阶段/闸门触发器、真执行、去重与成本开关
v2.0–v2.4	组织化	图标栏/深删/角色抽屉、SSE/附件/Trace、RBAC+审批续跑、FinOps、离线评测、分层记忆
v3.0–v3.2	治理	经验审核、MCP 外部工具、多租户、中文报错、SMTP、Role Alignment、一票否决、红线 L0
v4.0–v4.3	云端化	DEPLOY/nginx/gunicorn、企微群机器人、动态财务预算引擎、意图分类、工具预算
v4.4–v4.5	交付化	动态 WBS + 黑板、多格式产物、release bundle、自定义流程模板、级联删除
v4.6–v4.9	打磨	清理路由、批量清理、账户偏好、任务级联删、审批批处理、提示词模板、FinOps 导出
v5.0–v5.1	指挥舱	项目直派、预算预设、治理知识检索、角色生命周期、遥测总线、双内核、MCP 交易所、赛博指挥舱

> 节奏观察：从 v4.4 起提交密度明显加快（一天内多个特性），代价是测试与文档跟不上——这正是 §24 三类缺陷的来源。

22 • 已知缺陷与技术债（按严重度，全部可复现）

#	级别	问题	证据	影响
1	P0	project_stages 建表缺 3 列，干净库首次立项必崩	pipeline.py:51 DDL 无 role_tag/node_kind/gate_name；pipeline.py:259 却要写；只有 flows.py:173 的 ALTER 补	新部署/CI/换机 = 不可用；31 项测试因此红
2	P0	runner='acp' 实际跑 NativeKernel，DSH 根本不起	dsh_adapter.py:633 全量交给 kernel_router；默认 auto_failover + M0_PREFER_DSH=0	引擎语义失真；7 项守卫测试红；性能/能力与预期不符
3	P0	测试污染生产库	tests/test_v51_*.py 是唯一不设 DB_PATH 的测试；.env DB_PATH=./data/oa.db	已实测写入 PROJ-MCP-TEST（今日 09:06，已清理）
4	P1	产物目录分叉成两份	runner_native.py:49 写仓库 workspace/；pipeline._wdir 写 %LOCALAPPDATA%	同项目两处同名目录，出货包可能打包错版本
5	P1	明文 CEO 密钥在仓库根	e2e_supervisor.py:25-26	一次 git add -A 即进公开仓
6	P1	版本号与安装包停摆	main.py:88 / ops.py:21 / tauri.conf.json = 4.3.0；dist 只有 3.2.0、4.3.0	About 页比实际落后两个大版本；v4.4+ 无桌面版
7	P2	仓库根跑 pytest 收集即中断	workspace/projects/*/test_check.py 同名冲突；无 pytest 配置固定 testpaths	任何人第一次跑测试都失败
8	P2	v4.1 流程断言未随 9 阶段更新	test_v41_flows.py:69 断言 8 阶段；FLOW-STANDARD 与 FLOW-SOFTWARE 完全重复	3 项测试红 + 模板列表冗余
9	P2	DESIGN_GAPS 台账停在 §68（v3.2）	DESIGN_GAPS.md 章节尾号	v4.4–v5.1 的环境坑没有编号记录，新人会重复踩
10	P2	启动即打企微 API	recover_interrupted → auto_open，实测 6 条 60020 IP 不在白名单	日志噪音；生产环境会真发消息
11	P3	空库文件与 favicon	data/agent_os.db、data/oaagent.db 均 0 字节	误导排查
12	P3	前端单文件过大	App.jsx 3,569 行，14 视图里 7 个内联	改动半径大，回归风险高

23 • 数据在告诉我们什么（产品信号）

抛开代码，只看库里 597 个任务 / 621 次 Run 的真实分布，能读出四件事：

信号	数据	解读
通过率极低	rejected 459 / completed 30（2.4% 完成率）	判据比模型能力严得多，或判据与产出格式没对齐
执行其实很稳	runs succeeded 519 / failed 87（86% 执行成功）	跑不通不是问题，判不过才是问题
经验积压	approved 12 / pending 452	审核是人工瓶颈，导致学习闭环几乎不转
项目半途	done 2 / blocked 3 / active 2	7 个项目里 3 个卡在闸门，恢复工具（§11）用得上但没人用

> 这四条是下一步最该动的产品决策，比再堆功能更值钱。

24 • 后续优化方向（候选，按投入产出排序）

A. 地基（不做就会持续出血）

#	动作	代价	预期
A1	补 project_stages 迁移（DDL + 启动期 ALTER + 版本表）	0.5 天	新部署可用；31 项测试转绿
A2	让 acp 真的走 ACP：按 runner 名派发，不吞掉语义	0.5 天	引擎可预期；7 项测试转绿
A3	测试库隔离：conftest 统一 tmp DB_PATH + 禁写生产库断言	0.5 天	再也不会污染生产数据
A4	workspace 单一化 + pytest testpaths	0.5 天	产物不再分叉；测试可一键跑
A5	密钥出仓（.env / 环境变量）+ 提交前 secret 钩子	0.5 天	可安全开源

B. 产品闭环（直接影响老板体感）

#	动作	代价	预期
B1	判据与产出格式对齐：按 pack 生成判据模板，而不是一套判据打所有题材	2–3 天	完成率从 2.4% 提到 30%+ 合理区间
B2	经验审核批量化 + 自动预筛（相似度聚类后一次批 50 条）	2 天	452 条 backlog 可消化，学习闭环转起来
B3	失败诊断到「可执行下一步」：现在有 FailureDiagnosis，但要能一键修	2 天	3 个 blocked 项目可自助恢复
B4	一键重跑只重跑失败断言涉及的部分	3 天	省钱，且缩短迭代周期

C. 能力（拉高上限）

#	动作	代价	预期
C1	把「目标模式」引进来：长跑 Goal + 自主检查点，而不是一次对话	1 周	复杂需求不用人盯
C2	DAG 固定流程（应用中心）：把已验证的流程存成可复用应用	1 周	交付可复制，不再每次从零规划
C3	RAG / 代码索引：现在黑板上限 4000 字，大项目上下文会断	1 周	长项目不丢上下文
C4	MCP 工具市场：现在只有 3 个内置工具 + 用户自配	3–5 天	能力边界由生态扩展

D. 商业化与多租户

#	动作	代价	预期
D1	经验与评测按租户切分（当前残留）	2 天	SaaS 前提
D2	部门包 marketplace：blueprint 已有导出/导入，缺交易与授权	1 周	「卖部门」成立
D3	计费与配额：预算引擎已有，缺对外计量口径	1 周	可收费
D4	审计导出与合规报告（SOC2 风格）	1 周	企业采购门槛

> 建议路径：A 全做（2.5 天，止血）→ B1/B2（一周，把完成率与学习闭环拉起来）→ 再讨论 C。先做 C 而不做 B，会得到一个「能力更强但依然交不出活」的系统。

25 • 给推理模型的提问清单

如果你是被请来规划方向的模型，以下是我们希望你回答的问题，以及你必须知道的约束。

硬约束（不要建议违反）

- 单 worker + SQLite 是刻意选择：不要建议上 PostgreSQL 集群，除非同时给出迁移与运维成本。
- 判据必须可回溯到证据：不要建议「让模型自评通过」来提升通过率。
- 流程闸不可绕过：不要建议为了效率跳过阶段或闸门。
- 成本必须可见：任何新能力都要能计入 token/人民币归因。
- Windows 桌面是主战场：低完整性沙箱、UAC 静默、WebView2 坑都是真实现状。

我们希望你判断的问题

1. 完成率只有 2.4%（rejected 459 / completed 30）：这是判据过严、产出格式不匹配，还是任务本身就该失败？三条路分别怎么验证？
2. 452 条经验卡在 pending：应该改审核流程、改沉淀阈值，还是直接降级为「提示而非闸门」？
3. 双内核该怎么定位：Native 作为默认、ACP 作为高保障通道？还是反过来？切换应该由什么信号触发？
4. 「卖部门」（blueprint 市场）和「卖交付」（按项目收费）哪条路更适合当前形态？各自的阻塞点是什么？
5. 9 阶段是否过重：分析类、调研类需求也走 9 阶段吗？能不能按模板动态裁剪而不破坏闸门语义？
6. 前端 App.jsx 3,569 行该怎么拆：按视图拆组件，还是先引入路由与状态管理？
7. 如果只允许做三件事把「能跑」变成「能用」，你选哪三件？

不要建议的方向（已经评估过，结论是不做）

- 不要换底座去对标通用 Agent 平台（EvoFlow 那类）：我们的差异在判据+证据+预算，不在编排能力。
- 不要引入完整工作流引擎（Temporal/Airflow）：SQLite 触发器 + 状态机已经够，引入后运维成本翻倍。
- 不要做通用聊天机器人：闲聊已经用意图闸挡在外面，这是产品边界不是缺陷。

附录 A · 模块清单（按目录聚合）

目录	模块数	行数	主要模块（行数）
app/	37	8,160	pipeline(1501)、flows(679)、rbac(656)、finance(482)、experience(457)、mcp(389)、evals(377)、decisions(288)…
app/acceptance/	4	314	l0_rules(133)、l1_manual(80)、l2_scripts(72)、__init__(29)
app/api/	7	1,023	verbs(430)、tasks(274)、reports(122)、decisions(108)、memory(60)、relay(28)、__init__(1)
app/engine/	10	3,186	dsh_adapter(818)、runner_native(765)、runner_acp(521)、task_generator(353)、acp_client(207)、lowil(187)、repair(151)、kernel_router(108)…
app/mcp_bridge/	5	600	mcp_server(199)、pack_exporter(179)、api(111)、mcp_client(109)、__init__(2)
app/octo/	9	942	runner(229)、api(166)、guard(114)、intent(114)、inbox(109)、client(94)、agent(70)、tools(44)…
app/ui/	16	6,170	api(2855)、admin(841)、approval_flow(268)、roles(265)、store(258)、housekeeping(256)、ops(240)、dispatcher(237)…
app/wecom/	10	1,628	bridge(316)、approval(282)、api(211)、robot(208)、watcher(167)、sign_page(133)、guard(120)、client(105)…

合计 98 个模块、22,023 行。最大的三个：ui/api.py 2,855、pipeline.py 1,501、ui/admin.py 841。

附录 B • 接口清单（按标签，节选前 6 条）

标签组	端点数	示例路径（方法 路径）
ui	79	DELETE /ui/chats/{chat_id}；DELETE /ui/chats/{chat_id}/messages；DELETE /ui/evals/batches/{batch_id}；DELETE /ui/evals/sets/{set_id}；DELETE /ui/flow-templates/{flow_id}；DELETE /ui/projects/{project_id}…
ui-admin	26	DELETE /ui/account/preferences/{key}；DELETE /ui/departments/{dept_id}；DELETE /ui/files/{artifact_id}；DELETE /ui/groups/{chat_id}/members/{employee_id}；DELETE /ui/kb/{doc_id}；GET /ui/account…
extensions	14	DELETE /ui/mcp/{sid}；GET /ui/mcp；GET /ui/mcp/bindings/{agent_id}；GET /ui/notifications；GET /ui/smtp；GET /ui/wecom/robot…
wecom	14	GET /wecom/approval/list；GET /wecom/approval/status；GET /wecom/callback；GET /wecom/outbox；GET /wecom/sign；GET /wecom/status…
tasks	11	GET /audit/by-key/{key}；GET /locks；GET /tasks；GET /tasks/{task_id}；GET /tasks/{task_id}/timeline；POST /criteria/{criterion_id}/check…
octo	8	GET /octo/artifacts；GET /octo/status；GET /octo/watch；POST /octo/chains/reset；POST /octo/demo/ceo_group；POST /octo/mute/{bot_uid}…
ui-ops	7	DELETE /ui/jobs/{job_id}；GET /ui/about；GET /ui/alerts；GET /ui/jobs；POST /ui/alerts/{alert_id}/ack；POST /ui/jobs…
governance	7	DELETE /ui/experiences/{exp_id}；GET /ui/experiences；PATCH /ui/experiences/{exp_id}；POST /ui/experiences；POST /ui/experiences/preview；POST /ui/experiences/{exp_id}/review…
decisions	6	GET /decision-rules；GET /decisions；GET /decisions/{decision_id}；POST /decisions；POST /decisions/{decision_id}/decide；POST /decisions/{decision_id}/evaluate
mcp-exchange	6	GET /mcp-exchange/export/{pack_id}；GET /mcp-exchange/packs；GET /mcp-exchange/tools；POST /mcp-exchange/hire-remote；POST /mcp-exchange/import；POST /mcp-exchange/rpc
verbs	6	POST /verbs/attach_artifact；POST /verbs/emit_event；POST /verbs/report_heartbeat；POST /verbs/request_arbitration；POST /verbs/reserve_budget；POST /verbs/spawn_run
(none)	4	GET /；GET /api/telemetry/recent；GET /health；GET /review
memory	3	GET /memory；GET /memory/{memory_id}；POST /memory
reports	2	GET /packs；GET /reports/usage
housekeeping	2	GET /ui/maintenance/stats；POST /ui/maintenance/purge
relay	1	POST /relay/run

附录 C · 环境变量分组

组	变量
模型与运行	DEEPSEEK_API_KEY、MODEL_BASE_URL、RUNNER、UI_RUNNER、M0_RUN_TIMEOUT、M0_HEARTBEAT_SECONDS
存储与工作区	DB_PATH、DEFAULT_LEGAL_ENTITY_ID、M0_SANDBOX、M0_SANDBOX_ACP、M0_WORKSPACE
预算与成本	M0_BUDGET_LIMIT_TOKENS、M0_BUDGET_EST_TOKENS、UI_TASK_BUDGET、M0_PROJECT_TASK_BUDGET、M0_FLOW_STAGE_BUDGET、MODEL_PRICES_JSON、FINOPS_INPUT_RATIO
桌面与内核	M0_KERNEL_MODE、M0_PREFER_DSH、UI_DEV_LOGIN
企微	WECOM_CORP_ID、WECOM_AGENT_ID、WECOM_SECRET、WECOM_TOKEN、WECOM_AES_KEY、WECOM_CALLBACK_URL、WECOM_IP_ALLOWLIST、WECOM_MOCK、WECOM_WATCHER、WECOM_AUTORUN、WECOM_APPROVAL_POLLER、WECOM_APPROVAL_APPROVER、WECOM_APPROVAL_TEMPLATE_ID
Octo（已弃用）	OCTO_API_URL、OCTO_BOT_TOKEN、OCTO_HUMAN_TOKEN、OCTO_AUTORUN、OCTO_RUNNER、OCTO_MYSQL_*
评测	EVAL_JUDGE、EVAL_BUDGET

> .env 中实际存在 60 个键。Octo 相关已是遗留（源码封存在 vendor/，容器全部停止），新部署不必配。

附录 D • 术语表

术语	含义
六动词	ask / plan / build / check / decide / learn —— 底座对外的语义接口
闸门 gate	阶段通过的条件记录，未通过则阶段不许 done
一票否决 veto	研讨会中 audit/legal 提出反对，项目直接 blocked
黑板 blackboard	项目级共享上下文（project_artifacts），下游直接读结论
晶石 crystal	一次经验沉淀的可视化称呼，落在 org_experiences
park / resume	审批挂起运行并保留 session，批准后从断点继续
Native / ACP	进程内内核 / 外部 CLI 内核
pack	角色 + prompt + 判据 + 预算的能力包，决定任务用哪套模板
blueprint	部门包的可交易序列化格式（.metacorp.json）
L0/L1/L2	红线 / 人工证据 / 沙箱断言 三层判据